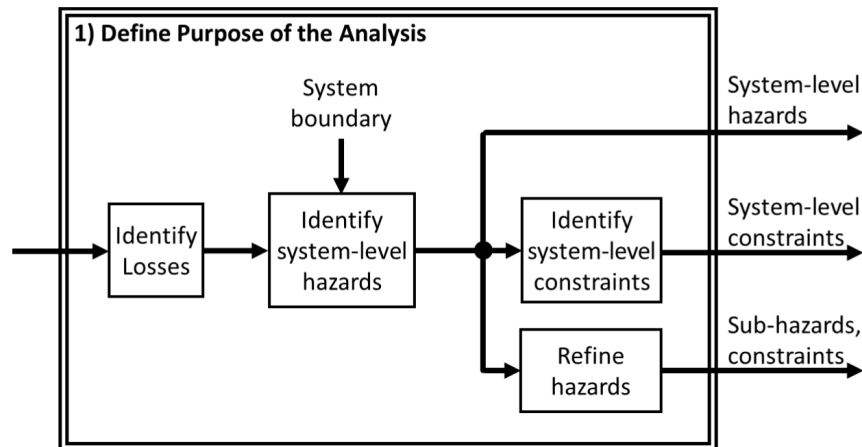


STPA ANALYSIS FOR A ROLE-BASED ACCESS CONTROL (RBAC) SUBSYSTEM

Last update: 06/10/2024

1. Define the purpose of the analysis (STPA Step 1)



1.1 Define and frame the problem

In modern software systems, particularly those handling sensitive information or critical functionalities, authentication and authorization mechanisms are paramount. These mechanisms ensure that only authenticated users with appropriate permissions can access specific resources or perform certain actions within the system. One common approach to implementing authentication and authorization is through Role-Based Access Control (RBAC), where users are assigned roles, and access rights are granted based on those roles.

RBAC is a widely used method for managing access to resources within an organization's information system. RBAC assigns permissions to users based on their roles, rather than specifying individual permissions for each user. This approach offers several advantages, including improved security and easier management of access rights.

1.2 Stakeholders

S1: Users

- Individuals who interact with the web application and require access to its features and resources. Users may include employees, customers, clients, administrators, or any other individuals authorized to use the system.

S2: Administrators:

- Responsible for managing the RBAC subsystem within the web application. They create, update, and delete user accounts, roles, and permissions. Administrators also handle user support and troubleshooting related to access issues.

S3: Developers

- Responsible for designing, implementing, and maintaining the RBAC subsystem within the web application. They ensure that the system functions correctly, securely, and efficiently, and they may also be involved in integrating RBAC with other parts of the application.

S4. Management:

- Oversee the overall operation and strategy of the web application. They may set policies and guidelines related to access control, define business requirements for RBAC implementation, and allocate resources for its development and maintenance.

S5. Security Personnel

- Concerned with ensuring the confidentiality, integrity, and availability of data within the web application. They may provide input on security requirements, conduct risk assessments, and monitor the RBAC subsystem for potential vulnerabilities or threats.

S6. Regulatory Authorities

- Depending on the industry and jurisdiction, regulatory authorities may have requirements or standards that the web application's RBAC subsystem must comply with. These stakeholders may provide guidelines or regulations related to data privacy, security, and access control.

S7. Third-party Service Providers:

- If the web application relies on third-party services or components for authentication or authorization, these providers become stakeholders as well. They may include identity providers, authentication services, or cloud service providers offering RBAC solutions.

S8. End Users' Organizations

- In cases where the web application serves organizations rather than individual users, the organizations themselves become stakeholders. They may have specific requirements for user management, access control, and data security within the application.

S9. Auditors

- Auditors may include internal auditors employed by the organization itself, external auditors hired by regulatory bodies or independent firms, or compliance officers responsible for ensuring adherence to industry standards and best practices. Auditors play a crucial role in evaluating the effectiveness of the RBAC subsystem within the web application by conducting audits, inspections, or assessments to identify any deficiencies, weaknesses, or non-compliance issues. They provide independent oversight and assurance to stakeholders regarding the system's security, integrity, and regulatory compliance.

1.3 System purpose and goal

SG-01: Ensure Authentication

- The system should accurately verify the identity of users seeking access to resources or functionalities.

SG-02: Enforce Authorization

- The system should grant access rights based on predefined roles and permissions, ensuring that users can only perform actions they are authorized to do.

SG-03: Maintain Data Confidentiality

- RBAC helps enforce confidentiality by ensuring that users only have access to the information and resources that are necessary for their roles.

SG-04: Maintain Data Integrity

- RBAC contributes to maintaining data integrity by preventing unauthorized users from making unauthorized changes to information.

SG-05: Facilitate Role Management

- The system should provide administrators with tools to efficiently manage roles, including creating, updating, and deleting roles as needed.

SG-06: Ensure Availability

- RBAC contributes to availability by ensuring that resources are accessible to authorized users when needed.

SG-07: Ensure Auditability

- The system should log user access and actions for auditing purposes, helping to trace any security breaches or unauthorized activities.

1.4 Assumptions**AS-1: System Boundaries**

- The RBAC system can be reused as a component in a web application. The RBAC system is responsible for managing user authentication, authorization, and access control within the application's defined boundaries.

AS-2: System Architecture

- The RBAC system is assumed to be designed as a modular component, capable of integrating seamlessly with an existing architecture of a web application. It interacts with other components such as user interfaces, databases, and application logic to enforce access control policies.

AS-3: Web Environment

- The RBAC system operates within a typical web application environment, with assumptions about factors such as network connectivity, server reliability, database availability, and web browser compatibility.

AS-4: Roles

- Users interacting with the web application are assumed to have varying roles, permissions, and access levels determined by the RBAC system.

AS-5: Regulatory and Legal compliance

- The RBAC system is assumed to comply with relevant laws, regulations, and industry standards governing data privacy, security, and access control.

AS-6: Scalability and Performance

- The RBAC system is assumed to be capable of accommodating a growing number of users, roles, and permissions as the web application scales. It should also be optimized for performance to handle concurrent user requests efficiently without compromising security.

1.5 Identify losses and accidents

L1: User cannot log in

L2: Disclosure of sensitive user data.

L3: User account compromised due to third-party intrusion.

L4: Unauthorized user gains access to confidential information.

L5: System inability to recover user data.

L6: User receives incorrect role from the Authorizer.

L7: User incorrectly authenticated by the Authenticator.

1.6 Identify system hazards and system level constraints**1.6.1. Identify system hazards**

H1: System overload. [L1, L5]

H2: Absence of password security policies. [L2, L3]

H3: No role assigned to an authenticated user. [L4, L6]

H4: No validation of credentials before authorization. [L2, L3, L4, L6, L7]

H5: Lack of data protection. [L2, L3, L5]

H6: User retains access after permissions are revoked. [L2, L3, L4]

1.6.2. Identify system constraints

SC1: The system must not be overloaded. [H1]

SC2: Password security policy must be in place. [H2]

SC3: The Authenticator must associate a role with an authenticated user. [H3]

SC4: Credentials must be validated before authorization. [H4]

SC5: The repository must have protection. [H5]

SC6: Users must lose access after permissions are revoked. [H6]

SC7: Only authenticated users are able to access the system. [H2] [H4]

2. Model the Control Structure (STPA Step 2)

2.1 System Components

- Usuário (User)
- Controlador de login (Login controller)
- Autenticador (Authenticator)
- Repositório (Repository)

2.2 Component responsibilities

User		
R1	Manter suas credenciais (username e password). As credenciais podem, por exemplo, serem salvas em um arquivo, anotadas em um caderno, ou até mesmo memorizadas.	SC2 SC7
R2	Fornecer suas credenciais quando solicitado.	SC2 SC7
R3	Assegurar que a senha associada ao usuário seja forte de acordo com a política de segurança da organização.	SC2

Login Controller		
R1	Tratar requisições de autenticação	SC7
R2	Gerenciar usuários	SC7

Authenticator		
R1	Validar credenciais fornecidas pelo usuário com credenciais armazenadas no repositório.	SC4
R2	Trabalhar em conjunto com o Autorizador para correta associação de papéis a usuários autenticados.	SC3
R3	Assegurar que o papel(is) adequado(s) seja(m) atribuído(s) a todo usuário autenticado.	SC3

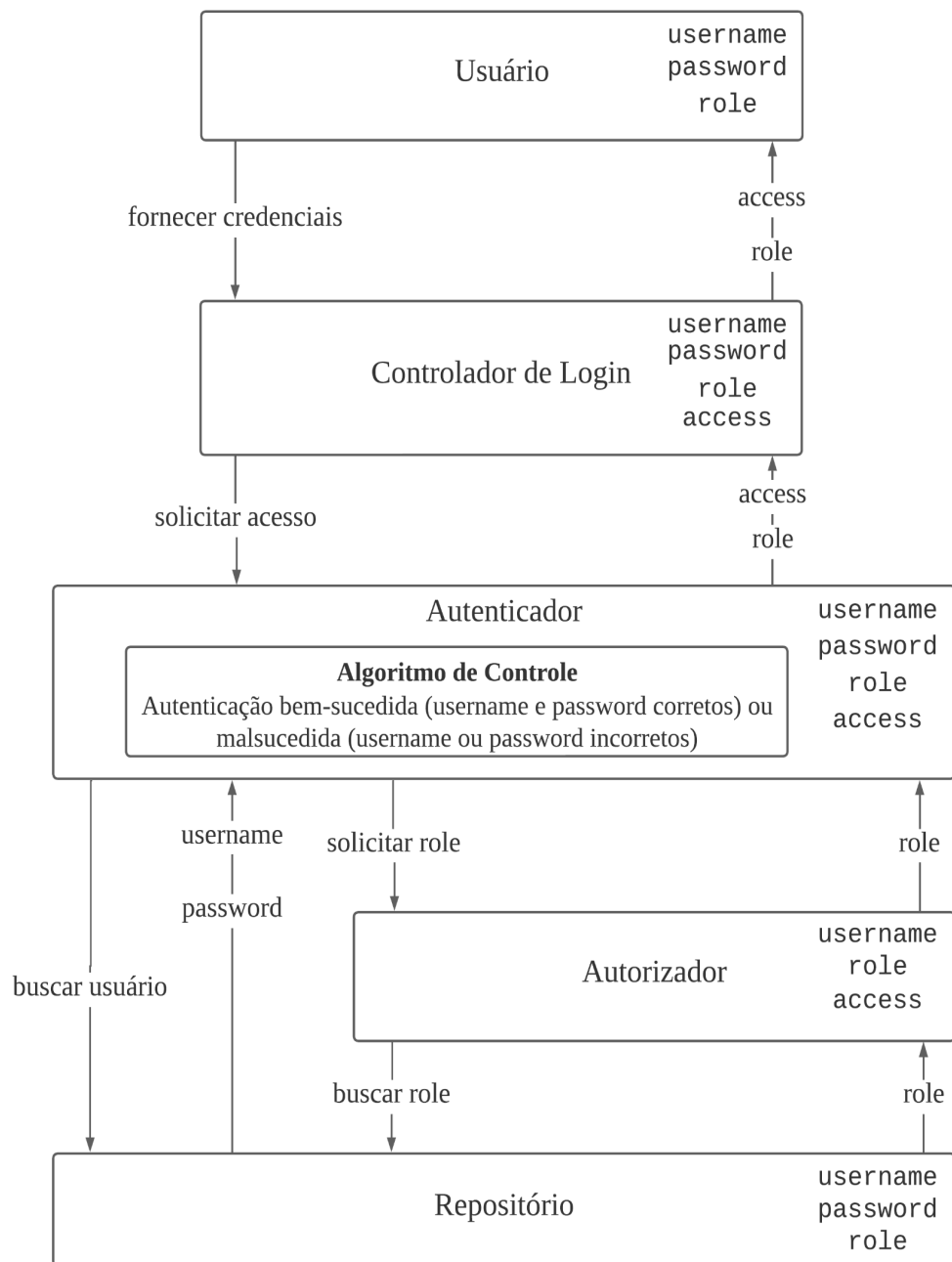
Autorizador		
R1	Definir o papel adequado para o usuário autenticado	SC3
R2	Gerenciar papéis e permissões	SC3 SC7

Repository		
R1	Manter as credenciais dos usuários com seus respectivos papéis.	SC5

2.3 System Level Control Structure

[Represent the System level control structure. Guideline: at this level try to use at most 3 components at a higher level of abstraction. The Control Actions and Feedback between components in the control structure are derived from the Responsibilities previously identified (and, hence, derived also from the System Safety Constraints)].

2.4 Control structure (Refinement/Zoom of the System Level control structure to be analyzed)



Na estrutura de controle temos um processo controlado (**Repositório**) e quatro controladores: **Usuário**, **Controlador de Login**, **Autenticador** e **Autorizador**.

O controlador **Usuário** é responsável por emitir a *control action* "fornecer credenciais" para tentar obter acesso ao sistema. Para isso, ele envia as variáveis "username" e "password" para validação no **Repositório**.

O **Controlador de Login** é responsável por intermediar o acesso entre o controlador **Usuário** e o controlador **Autenticador**, através da *control action* "solicitar acesso".

O controlador **Autenticador** é responsável por realizar a autenticação através da *control action* "buscar usuário" (validação do conjunto "username" e "password" no **Repositório**).

Caso o conjunto de "username" e "password" fornecidos não sejam encontrados no **Repositório**, o **Autenticador** devolve ao **Controlador de Login** o "access" com valor "Not Allowed" e o "role" com valor "Unknown".

Caso o conjunto "username" e "password" sejam encontrados no **Repositório**, o **Autenticador** emite a *control action* "solicitar role" ao **Autorizador**, que por sua vez fornece a *control action* "buscar role" ao **Repositório**.

A resposta do **Repositório** é o *role* encontrado para o "username" fornecido. O **Autorizador** devolve o conteúdo da variável "role" ao **Autenticador** que por sua vez conclui a autorização, enviando ao **Controlador de Login** e **Usuário** a concessão do acesso (quando "username" é "Valid", "password" é "Valid" e "role" é "Admin" ou "User") ou negando acesso (quando "username" é "Valid", "password" é "Valid" e "role" é "Unknown").

Usuário:

Variáveis	Valores
username	[Valid / Not Valid / Provided / Not Provided]
password	[Valid / Not Valid / Provided / Not Provided]
role	[Admin / User / Unknown]

Controlador de Login:

Variáveis	Valores
username	[Valid / Not Valid / Provided / Not Provided]
password	[Valid / Not Valid / Provided / Not Provided]
role	[Admin / User / Unknown]
access	[Allowed / Not Allowed]

Autenticador:

Variáveis	Valores
username	[Valid / Not Valid / Provided / Not Provided]
password	[Valid / Not Valid / Provided / Not Provided]
role	[Admin / User / Unknown]
access	[Allowed / Not Allowed]

Autorizador:

Variáveis	Valores
username	[Valid / Not Valid / Provided / Not Provided]
role	[Admin / User/ Unknown]
access	[Allowed / Not Allowed]

Repositório:

Variáveis	Valores
username	[Valid / Not Valid / Provided / Not Provided]
password	[Valid / Not Valid / Provided / Not Provided]
role	[Admin / User / Unknown]

3. Identify Unsafe Control Actions (STPA Step 3)

3.1 Identify Unsafe Control Actions – UCAs

USUÁRIO				
Control action	Not providing causes hazard	Providing causes hazard	Too early, too late, out of order	Stopped too soon/Applied tool long
Fornecer credenciais	UCA-1: Usuário não fornece fornecer credenciais quando o nome de usuário é fornecido, a senha é fornecida [H-1] UCA-2: Usuário não fornece fornecer credenciais quando o nome de usuário não foi fornecido, a senha foi fornecida [H-1] UCA-3: Usuário não fornece fornecer credenciais quando o nome de usuário é fornecido, a senha não é fornecida [H-1]	Sem Perigo	Sem Perigo	N/A

CONTROLADOR DE LOGIN				
Control action	Not providing causes hazard	Providing causes hazard	Too early, too late, out of order	Stopped too soon/Applied tool long
Solicitar acesso	UCA- 4: Controlador de Login não fornece solicitar acesso quando o nome de usuário é fornecido, a senha é fornecida [H-1] UCA- 5: Controlador de Login não fornece solicitar acesso quando o nome de usuário não é fornecido, a senha é fornecida [H-1] UCA- 6: Controlador de Login não fornece solicitar acesso quando nome de usuário não é fornecido, senha não é fornecida [H-1] UCA- 7: Controlador de Login não fornece solicitar acesso quando o nome de usuário é fornecido, a senha não é fornecida [H-1]	Sem Perigo	Sem Perigo	N/A

AUTENTICADOR				
Control action	Not providing causes hazard	Providing causes hazard	Too early, too late, out of order	Stopped too soon/Applied tool long
Buscar usuário	UCA-8: Autenticador não fornece buscar usuário quando o nome de usuário e a senha são fornecidos. [H4] UCA-9: Autenticador não fornece buscar usuário quando o nome de usuário não é fornecido e a senha é fornecida. [H4] UCA-10: Autenticador não fornece buscar usuário quando o nome de usuário é fornecido e a senha não é fornecida. [H4] UCA-11: Autenticador não fornece para buscar usuário quando o nome de usuário e a senha não são fornecidos. [H4]	Sem Perigo	UCA-12: Autenticador fornece buscar usuário muito cedo quando o nome de usuário não é fornecido e a senha não é fornecido. [H2]	N/A
Solicitar role	UCA-13: Autenticador não fornece solicitar role quando o nome de usuário é válido e a senha é válida. [H1]	UCA-14: Autenticador fornece solicitar role quando o nome de usuário não é válido e a senha é válida. [H2, H4]	UCA-17: Autenticador fornece solicitar role muito cedo quando o nome de usuário é fornecido e senha é fornecido. [H2, H4]	N/A

		UCA-15: Autenticador fornece solicitar role quando o nome de usuário é válido e a senha não é válida. [H2, H4] UCA-16: Autenticador fornece solicitar role quando o nome de usuário e a senha não são válidos. [H2, H4]	UCA-18: Autenticador fornece solicitar role muito cedo quando o nome de usuário foi fornecido e a senha não é fornecida. [H2, H4] UCA-19: Autenticador fornece solicitar role muito cedo quando o nome de usuário não é fornecido e a senha é fornecida. [H2, H4] UCA-20: Autenticador fornece solicitar role muito cedo quando o nome de usuário não é fornecido e a senha não é fornecido. [H2, H4]	
--	--	---	---	--

AUTORIZADOR				
Control action	Not providing causes hazard	Providing causes hazard	Too early, too late, out of order	Stopped too soon/Applied tool long
Buscar role	UCA-21: Autorizador não fornece buscar role quando o nome de usuário é válido e senha é válida. [H1, H6]	UCA-22: Autorizador fornece buscar role quando nome de usuário não é válido e senha é válida. [H2, H3, H4, H6] UCA-23: Autorizador fornece buscar role quando nome de usuário é	UCA-25: Autorizador fornece buscar role muito cedo quando nome de usuário é fornecido e senha é fornecido. [H4, H6] UCA-26: Autorizador fornece buscar role muito cedo quando nome de	N/A

		válido e senha não é válida. [H2, H3, H4, H6] UCA-24: Autorizador fornece buscar role quando nome de usuário não é válido e senha não é válido. [H2, H3, H4, H6]	usuário não é fornecido e senha é fornecido. [H4, H6] UCA-27: Autorizador fornece buscar role muito cedo quando nome de usuário é fornecido e password não é fornecido. [H4, H6] UCA-28: Autorizador fornece buscar role muito cedo quando nome de usuário não é fornecido e senha não é fornecido. [H4, H6]	
--	--	---	---	--

3.2 Identify controller constraints

Unsafe Control Actions	Controller constraint(s)
UCA-1	C-1, C-2
UCA-2	C-2
UCA...	C..
UCA-n	C-n